

Cyber Threat Intelligence

Executive Briefing

Report Date: July 04, 2026

Generated: 2026-07-04 20:24 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
3	11	5	1	20

2. Executive Summary

As of July 04, 2026, the security operations center has concluded the analysis of 20 identified vulnerabilities, comprised of 3 Critical, 11 High, 5 Medium, and 1 Low severity findings. This volume of threats indicates an elevated organizational risk posture, characterized by vulnerabilities that, if exploited, pose a severe threat to the confidentiality, integrity, and availability of our core infrastructure. The most significant threat is CVE-2026-49360, Unauthenticated SQL Execution in Recce Server, which represents the highest priority due to the potential for direct backend database compromise via unauthenticated input injection. We recommend an immediate transition to an emergency defensive posture, prioritizing the remediation or isolation of all systems identified as Critical. Proactive containment protocols must be initiated forthwith to mitigate exposure across the enterprise environment.

3. Critical Action List

- Immediate isolation of the Recce Server infrastructure to mitigate CVE-2026-49360, with full patching completed within 6 business hours.
- Mandatory rotation of JWT authentication secrets across all 9router instances to remediate CVE-2026-49352, to be executed within 6 business hours.
- Deployment of global input validation filters for the LaunchServer FileServerHandler to neutralize CVE-2026-54617 within 12 business hours.
- Suspension of external access to affected fast-mcp-telegram packages until a verified patch for CVE-2026-52830 is deployed, mandatory within 12 business hours.
- Implementation of strict Host header validation policies for Steeltoe management ports to resolve CVE-2026-50194, to be completed within 24 business hours.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-49360	Unauthenticated SQL Execution in ...	9.8	Critical	88/100	CWE-73
CVE-2026-49352	JWT Authentication Bypass via Har...	9.8	Critical	88/100	CWE-798
CVE-2026-54617	Unauthenticated Path Traversal in...	7.5	High	88/100	CWE-22
CVE-2026-52830	Bearer Token Path Traversal in fa...	9.4	Critical	85/100	CWE-22
CVE-2026-50194	Management Port Isolation Bypass	8.2	High	74/100	CWE-288
CVE-2026-2092	Unauthorized Access via Improper ...	7.7	High	69/100	CWE-1287
CVE-2026-49353	Access Gate Bypass via Header Spo...	7.5	High	68/100	CWE-290
CVE-2026-46599	Resource Exhaustion in TIFF PackB...	7.5	High	68/100	CWE-770
CVE-2026-52792	Script Source Disclosure on Windo...	7.5	High	68/100	CWE-69
CVE-2026-50200	Sensitive Information Leak in Env...	7.5	High	68/100	CWE-200
CVE-2026-50196	Denial of Service via Eureka Regi...	7.5	High	68/100	CWE-20
CVE-2026-49289	Denial of Service via XPath Trans...	7.5	High	68/100	CWE-400
CVE-2026-52829	Memory Corruption in Zebra Addres...	7.5	High	68/100	CWE-617
CVE-2026-52834	Out-of-Bounds Write in jxl-grid	8.6	High	66/100	CWE-122
CVE-2026-49284	Improper SAML Response Validation	6.8	Medium	64/100	CWE-345
CVE-2026-50201	Excessive Permissions on Sensitiv...	6.5	Medium	59/100	CWE-269
CVE-2026-50202	Insecure JWKS Cache Persistence	5.9	Medium	53/100	CWE-668
CVE-2026-50267	Insecure Storage of TLS Private K...	4.7	Medium	42/100	CWE-312
CVE-2026-49292	Unintended Access to Initializati...	6.5	Medium	30/100	CWE-862
CVE-2026-50268	Insecure Padding Selection in Ste...	1.9	Low	12/100	CWE-256

5. Detailed Vulnerability Findings

CVE-2026-49360

Finding: Unauthenticated SQL Execution in Recce Server

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-73

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

The Recce server's backend interaction layer fails to validate inputs before passing them to the DuckDB engine, leading to arbitrary SQL execution. The root cause is the absence of input sanitization for local file system operations enabled

by the database connector. This allows an unauthenticated remote attacker to perform unauthorized file reads or writes on the host system.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the Recce server management endpoint. The attacker sends a crafted SQL query targeting the DuckDB interface to read sensitive system configuration files. The server process executes the malicious query with elevated privileges because it fails to filter SQL commands. This results in the exfiltration of sensitive host data and potential modification of application files.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49360>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49360>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49360>

CVE-2026-49352

Finding: JWT Authentication Bypass via Hardcoded Secret

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-798

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1185, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

9router uses a hardcoded default fallback JSON Web Token (JWT) secret for authentication verification. The root cause is the inclusion of sensitive cryptographic material within the source code, which serves as a fallback when configuration files are missing. This allows an unauthenticated attacker to forge valid authentication tokens and bypass identity verification completely.

Proof of Concept (PoC):

An unauthenticated remote attacker obtains the known hardcoded JWT secret from the repository source. The attacker crafts a valid JWT payload claiming to be an administrator and signs it with the exposed secret. The application verifies the signature against the hardcoded secret and grants the attacker an authenticated session. This results in full administrative access to the platform without any valid user credentials.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49352>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49352>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49352>

CVE-2026-54617

Finding: Unauthenticated Path Traversal in FileServerHandler

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 88/100 | CWE: CWE-22

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1083, T1555

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The LaunchServer component's FileServerHandler suffers from an unauthenticated path traversal vulnerability that allows access to arbitrary files on the system. The root cause is insufficient sanitization of file paths provided by users, allowing the inclusion of directory traversal characters like dot-dot-slash. This enables an attacker to read any file on the server's local file system with the permissions of the running application.

Proof of Concept (PoC):

An unauthenticated remote attacker sends an HTTP GET request to the file server endpoint with a path parameter containing ../ sequences. The FileServerHandler fails to validate the requested directory, mapping the path to sensitive files outside the intended web root. The server returns the contents of the file, such as configuration files or shadow files. This results in full disclosure of sensitive server-side information.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54617>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54617>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54617>

CVE-2026-52830

Finding: Bearer Token Path Traversal in fast-mcp-telegram

CVSS v3.1 Score: 9.4 | Severity: Critical | Urgency Score: 85/100 | CWE: CWE-22

Score Provenance: CNA Official

MITRE ATT&CK: T1083, T1555

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

The fast-mcp-telegram package fails to restrict access to reserved Telegram sessions, allowing bypass through bearer token path traversal. The root cause is the insecure concatenation of user-supplied token strings into filesystem paths, allowing for directory traversal. This enables an attacker to access session files of other users or unauthorized application data.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to the Telegram session interface with a bearer token path set to ../../etc/shadow. The application processes the token without validating the traversal sequences, allowing it to open unauthorized files from the host disk. The application exposes the contents of the files back to the user. This results in the compromise of sensitive credentials or Telegram session data.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52830>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52830>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52830>

CVE-2026-50194

Finding: Management Port Isolation Bypass

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-288

Score Provenance: CNA Official

MITRE ATT&CK: T1133

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe is vulnerable to management-port isolation bypass via spoofed Host headers in incoming requests. The root cause is the reliance on the HTTP Host header to determine if a request is intended for the internal management port rather than verifying the actual network interface. This allows a remote attacker to gain access to restricted management endpoints from public-facing ports.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a crafted request to the public application endpoint. The attacker sets the Host header to point to the management port configuration. Steeltoe interprets the Host header and routes the request internally to the management services that are supposed to be isolated. This results in unauthorized access to sensitive management and monitoring APIs.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50194>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50194>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50194>

CVE-2026-2092

Finding: Unauthorized Access via Improper SAML Validation

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-1287

Score Provenance: CNA Official

MITRE ATT&CK: T1558

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:L/A:L

Attack Vector	Network
Privileges Required	Low
Scope	Changed
Integrity Impact	Low

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	Low

Description:

Keycloak suffers from unauthorized access due to improper validation of encrypted SAML assertions. The root cause is a failure in the security framework to adequately verify the integrity and origin of encrypted assertion elements during the processing phase. This allows an attacker to manipulate assertions, potentially gaining unauthorized privileges or

accessing other user sessions.

Proof of Concept (PoC):

An authenticated user with low privileges intercepts a legitimate SAML response from the IDP. The attacker modifies the encrypted assertion component while keeping the overall envelope signed, leveraging the validation logic weakness in Keycloak. The server decrypts the malformed but signed assertion and accepts the manipulated attributes. This results in privilege escalation to an administrative or unintended account level.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-2092>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-2092>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-2092>

CVE-2026-49353

Finding: Access Gate Bypass via Header Spoofing

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-290

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1133, T1036

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The 9router routing component fails to correctly validate the Host header, allowing an bypass of local-only access restrictions. The root cause is an insecure reliance on untrusted HTTP headers for origin verification during the routing process. This enables remote attackers to access restricted internal gateways that were intended to be accessible only from the localhost.

Proof of Concept (PoC):

An unauthenticated remote attacker crafts an HTTP request targeting the 9router internal administrative panel. The attacker modifies the Host header to appear as localhost while routing the packet through the public interface. The server incorrectly validates the identity based on the spoofed header and grants access to the internal gate. This results in unauthorized access to restricted internal resources and configuration APIs.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49353>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49353>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49353>

CVE-2026-46599

Finding: Resource Exhaustion in TIFF PackBits Decompression

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-770

Score Provenance: Estimated (No Official CVSS) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The golang.org/x/image/tiff library exhibits excessive resource consumption during the PackBits decompression phase when processing malformed images. The root cause is the lack of strict input length validation during the decompression of repeated data blocks. This allows an attacker to trigger an out-of-memory condition or high CPU load, leading to a Denial of Service (DoS) of the affected service.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specifically crafted TIFF image to an endpoint processing file uploads. The library's PackBits decompression function encounters a malicious length indicator and attempts to allocate an infinite or massive memory block. The server process consumes all available system memory to handle the decompression attempt. This results in a crash of the application and a complete service outage.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-46599>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-46599>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-46599>

CVE-2026-52792

Finding: Script Source Disclosure on Windows

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-69

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1040, T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Algernon web server is vulnerable to server-side script source disclosure on Windows systems via the use of NTFS alternative data streams. The root cause is the failure of the server's path handler to normalize file extensions before reading files from the disk. This allows a remote attacker to download the raw source code of sensitive scripts by appending specific characters to the filename.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies a script file handled by the Algernon web server. The attacker submits a request for the script file with a specific suffix that triggers the NTFS stream disclosure behavior. The server misidentifies the request and serves the raw source code instead of executing the script. This results in the exposure of potentially sensitive logic and credentials embedded within the scripts.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52792>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52792>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52792>

CVE-2026-50200

Finding: Sensitive Information Leak in Env Sanitizer

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-200

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe's environment variable sanitizer fails to filter connection strings, leading to the exposure of embedded database passwords. The root cause is an incomplete regular expression or filtering logic in the sanitization component that misses specific connection string formats. This results in the leakage of plaintext database credentials to authorized users or through monitoring endpoints.

Proof of Concept (PoC):

An unauthenticated remote attacker accesses the application's environment info endpoint. The endpoint returns a JSON object containing the full list of environment variables, including the connection strings where the password is still visible. The attacker extracts the database password from the connection string. This results in unauthorized access to the backend database using the recovered credentials.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50200>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50200>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50200>

CVE-2026-50196

Finding: Denial of Service via Eureka Registry Poisoning

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-20

Score Provenance: CNA Official

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Steeltoe.Discovery.Eureka is vulnerable to registry poisoning when an unrecognized DataCenterInfo.Name is processed during a registry fetch. The root cause is a failure in the library to gracefully handle unexpected input formats in discovery responses, leading to an application-wide exception. This allows an attacker to cause a denial of service for all dependent services relying on the registry.

Proof of Concept (PoC):

An attacker creates a malicious Eureka server node or intercepts a registry fetch response sent to the Steeltoe client. The attacker includes an unrecognized DataCenterInfo.Name value in the registry payload. The Steeltoe client attempts to process the unexpected data, hits an unhandled exception, and crashes the service discovery module. This results in all dependent microservices losing connectivity to the registry, effectively causing a cluster-wide service failure.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50196>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50196>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50196>

CVE-2026-49289

Finding: Denial of Service via XPath Transformation

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
Privileges Required	None	User Interaction	None
Scope	Unchanged	Confidentiality Impact	None
Integrity Impact	None	Availability Impact	High

Description:

SimpleSAMLphp is susceptible to a Denial of Service attack via the processing of complex XPath transforms in SAML assertions. The root cause is the recursive nature of the XML parsing engine when handling deeply nested or crafted XPath expressions. This allows an attacker to consume excessive CPU resources and render the authentication service unresponsive.

Proof of Concept (PoC):

An unauthenticated remote attacker submits a specially crafted SAML response containing highly optimized XPath transformation instructions to the SimpleSAMLphp SP. The server attempts to process the XML structure and enters a computational loop or hits a high-depth limit. The server's CPU usage spikes to 100%, causing a service outage for all users attempting to authenticate. This results in a temporary denial of service for the entire application.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49289>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49289>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49289>

CVE-2026-52829

Finding: Memory Corruption in Zebra Address Book

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-617

Score Provenance: Estimated (Unverified) - Vector Recalculated
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network	Attack Complexity	Low
---------------	---------	-------------------	-----

Privileges Required	None
Scope	Unchanged
Integrity Impact	None

User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The Zebra Address Book experiences abnormal behavior and termination due to mismanaged IPv4-mapped memory pool allocations. The root cause is the incorrect handling of memory pointer arithmetic when processing mixed IPv4/IPv6 addresses, leading to an assertion failure. This results in the application crashing whenever it encounters specifically crafted network address input.

Proof of Concept (PoC):

An unauthenticated remote attacker inputs a malformed IPv4-mapped address into the Zebra Address Book's search function. The memory management routine encounters an invalid pointer state and triggers a software assertion failure. The application immediately terminates to avoid inconsistent memory state. This results in a persistent denial of service for the address book utility.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52829>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52829>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52829>

CVE-2026-52834

Finding: Out-of-Bounds Write in jxl-grid

CVSS v3.1 Score: 8.6 | Severity: High | Urgency Score: 66/100 | CWE: CWE-122

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	High

Description:

The jxl-grid library on 32-bit platforms suffers from an out-of-bounds write due to an integer overflow during grid indexing calculations. The root cause is the lack of proper bounds checking when calculating offset addresses for large image data buffers. This allows an attacker to overwrite adjacent memory, potentially leading to arbitrary code execution if the input is carefully crafted.

Proof of Concept (PoC):

An unauthenticated remote attacker uploads a specially crafted 32-bit image file to the target application. The jxl-grid parser performs an invalid memory calculation leading to an integer overflow that wraps around the buffer boundary. The library writes data to unauthorized memory locations. This results in the corruption of heap memory and potential execution of malicious code under the application's context.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52834>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52834>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52834>

CVE-2026-49284

Finding: Improper SAML Response Validation

CVSS v3.1 Score: 6.8 | Severity: Medium | Urgency Score: 64/100 | CWE: CWE-345

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1204

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	Required
Confidentiality Impact	High
Availability Impact	None

Description:

The SimpleSAMLphp SP component accepts SAML responses from an unexpected Identity Provider when unsigned responses are paired with specific signed assertions. The root cause is a flaw in the SAML validation logic where it incorrectly correlates `InResponseTo` fields across mismatched IDP and SP assertions. This allows an attacker to inject a legitimate assertion from a different context to authenticate against the Service Provider.

Proof of Concept (PoC):

An unauthenticated remote attacker forces a victim to interact with a malicious SAML endpoint that returns a signed assertion. The attacker forwards this assertion to the vulnerable SimpleSAMLphp SP, which fails to verify the response origin due to the flawed `InResponseTo` correlation logic. The SP validates the assertion as legitimate, granting the attacker access to the victim's session. This results in account takeover or unauthorized access to the service provider.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49284>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49284>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49284>

CVE-2026-50201

Finding: Excessive Permissions on Sensitive Actuators

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-269

Score Provenance: CNA Official

MITRE ATT&CK: T1068, T1555

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Steeltoe management actuators for sensitive operations like heap dumps and environment variables only require Restricted privileges for access. The root cause is a misconfiguration in the default security policy for these diagnostic endpoints. This allows low-privileged users to leak critical system information or perform actions that should be reserved for administrative accounts.

Proof of Concept (PoC):

An authenticated user with low-level privileges navigates to the /actuator/heapdump endpoint of the Steeltoe application. The server checks for the 'Restricted' role, which the attacker possesses, and permits the download of the entire application memory heap. The attacker inspects the heap dump for sensitive information like session tokens and environment variables. This results in the exposure of highly sensitive system data.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50201>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50201>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50201>

CVE-2026-50202

Finding: Insecure JWKS Cache Persistence

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-668

Score Provenance: CNA Official
MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

The Steeltoe library maintains a static JWKS cache that is shared across schemes and never properly invalidated. The root cause is the improper design of the caching mechanism, which does not account for multi-tenancy or key rotation events. This allows an attacker to potentially inject or persist outdated and malicious public keys within the cache.

Proof of Concept (PoC):

An administrator-level attacker manipulates the JWKS endpoint from which Steeltoe fetches keys, or injects a malicious key into the cache. Because the cache is static and never expires, the malicious public key remains in memory for the lifetime of the application instance. Subsequent tokens signed with a matching private key by the attacker are accepted by the application. This results in persistent, unauthorized authentication bypass.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50202>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50202>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50202>

CVE-2026-50267

Finding: Insecure Storage of TLS Private Keys

CVSS v3.1 Score: 4.7 | Severity: Medium | Urgency Score: 42/100 | CWE: CWE-312

Score Provenance: CNA Official
MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Local
Privileges Required	Low

Attack Complexity	High
User Interaction	None

Scope	Unchanged
Integrity Impact	None

Confidentiality Impact	High
Availability Impact	None

Description:

Steeltoe writes TLS private keys to the /tmp directory with default global read permissions and fails to delete them. The root cause is an insecure file management practice within the initialization routine that does not ensure restricted permissions on generated secrets. This allows any local user with access to the server's temporary storage to recover the TLS private keys.

Proof of Concept (PoC):

A local user on the host server monitors the /tmp directory while the Steeltoe application is starting up. The attacker observes the application creating a file containing the TLS private key with insecure permissions. The attacker copies this file to their own local directory. This results in a full compromise of the application's TLS traffic through the acquisition of the private key.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50267>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50267>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50267>

CVE-2026-49292

Finding: Unintended Access to Initialization Page

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 30/100 | CWE: CWE-862

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	Low

Description:

The Kiwi TCMS application continues to render and respond to requests on the /init-db/ initialization endpoint even after the initial installation process is complete. The root cause is an improper check for the application state, which fails to disable the setup utility following the first use. This allows an unauthorized user to potentially interfere with the database configuration state.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to the /init-db/ endpoint after the system has been fully deployed. The server processes the request as if it were a new installation, potentially allowing the attacker to reconfigure or reset the database connection parameters. This results in a degradation of system integrity and availability through unauthorized configuration changes.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49292>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49292>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49292>

CVE-2026-50268

Finding: Insecure Padding Selection in Steeltoe

CVSS v3.1 Score: 1.9 | Severity: Low | Urgency Score: 12/100 | CWE: CWE-256

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Local	Attack Complexity	High
Privileges Required	High	User Interaction	None
Scope	Unchanged	Confidentiality Impact	Low
Integrity Impact	None	Availability Impact	None

Description:

The Steeltoe library defaults to using the insecure PKCS#1 v1.5 padding scheme even when OAEP is requested. The root cause is an implementation error in the cryptographic library's wrapper that silently falls back to legacy padding. This potentially makes the cryptographic operations vulnerable to side-channel attacks and padding oracle exploits.

Proof of Concept (PoC):

A local attacker with high administrative privileges examines the crypto-configuration of a running Steeltoe service. The attacker monitors the cryptographic traffic and identifies that RSA operations utilize PKCS#1 v1.5 padding despite the OAEP setting. The attacker proceeds to perform a padding oracle attack on the target system. This results in the leakage of small amounts of encrypted material due to improper cryptographic implementation.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50268>
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50268>
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50268>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>

- OpenCVE -- <https://www.opencve.io/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>